Cinema Focus main website: AWS security, isolation and infrastructure audit

Read-only audit. No AWS resource, DNS, Vercel setting or source file was changed. Account 134283612566 (profile **store**), region ap-south-1, stack cinemafocus-aws-prod, date 2026-10-31.

Scope and limits

Covered: repo code (infra Lambdas, Next API routes, proxy), deployed inventory, IAM, API Gateway, Cognito, S3, CloudFront, DynamoDB, CloudWatch. **Not done:** local lint/unit/serverless package checks, Vercel environment review (no access), live attack tests, final per-Lambda IAM mapping. F-01 is a static finding and was not tested live.

Findings by severity

ID	Severity	Finding	Evidence	Store impact
F-01	Critical	Likely admin takeover via Cognito self-signup. AllowAdminCreateUserOnly=false, custom:role is mutable, app client WriteAttributes=null (all writable). Anyone could sign up with custom:role=admin, confirm by email, log in. Lambda trusts claims[custom:role].	Cognito pool/client config; infra/lib/aws/authz.js	None
F-02	Critical	The 'store' profile uses root account access keys.	sts get-caller-identity returns arn:aws:iam::134283612566:root	Yes (same account). Replace with IAM/SSO role.
F-03	High	Local API_GATEWAY_URL points at q3q7swvqu2, which is not in this account. Live API is 57z1vidohf. Cause of the press-releases 404 (every route 404s).	curl 404 on all routes; apigatewayv2 get-apis	None
F-04	High	Uncommitted infra/serverless.yml would break production: renames bucket (replacement), removes CloudFront/OAC, makes bucket public (Principal *), changes CDN_DOMAIN. Targets account 756367305158. Do not deploy to this stack.	git diff; live bucket is private behind OAC	Quota only
F-05	High	Upload presign has no validation: folder, fileName, contentType client-controlled. Path traversal in key, HTML/SVG upload (stored XSS on CDN origin), no size cap. 10 MB and image checks exist only in the Next route.	infra/handlers/upload.js	None
F-06	High	No gateway throttling or WAF; /auth/login unthrottled; public writes (messages, stats) unlimited. Account Lambda concurrency is 10, so a flood throttles the store too. 63 throttles in 7 days.	get-stages; get-account-settings; CloudWatch	Yes (shared concurrency)
F-07	High	Public POST /stats accepts arbitrary date key (one item per value). POST /messages stores unvalidated, unbounded fields.	stats.js, messages.js	None
F-08	Medium	CORS AllowOrigins is *. Browser goes through the Next proxy, so this is unnecessary.	get-api	None
F-09	Medium	One role shared by all 39 Lambdas: public readers can write all tables and create/delete Cognito users and set passwords. No store ARNs in the policy (good).	Role inline policy	None
F-10	Medium	Mass assignment: users.update and pressReleases.update PutItem the raw body.	users.js, pressReleases.js	None
F-11	Medium	PITR disabled on all 9 tables; no deletion protection on Users.	describe-continuous-backups	None
F-12	Medium	Cognito: MFA off, USER_PASSWORD_AUTH on. Token verifier checks this pool's client, so store tokens are rejected (good).	Cognito config; authz.js	None
F-13	Medium	Alarms (lambda-error, billing) have zero notification actions.	describe-alarms	Partly

ID	Severity	Finding	Evidence	Store impact
F-14	Medium	CloudFront: minimum TLS TLSv1, no response-headers policy, no WAF, no alias.	get-distribution-config	None
F-15	Low	firebase-service-account.json is staged in git index and not in .gitignore. No commits contain it (never pushed). Real service-account key.	git ls-files; git log	None
F-16	Low	Lambda log groups have no retention; no tracing.	describe-log-groups	None
F-17	Low	No tests for infra/ or API routes.	repo	None
F-18	Info	Serverless pinned to v3; runtime nodejs20.x is fine for now.	serverless.yml	None
F-19	Info	Admin cookies set correctly: httpOnly, secure, sameSite=lax, 1 h ID token, 30 d refresh.	app/api/auth/login/route.js	None

Resource inventory

Resource	Main site	Store
Stack	cinemafocus-aws-prod	CinemaFocusStore-staging
API Gateway	57z1vidohf (39 routes, all NONE authorizer, CORS *)	5sp3yjfig9 (throttle 50 rps / burst 100)
Lambda	39 functions, nodejs20.x, 1024 MB, 6 s, one shared role	Separate functions and roles
DynamoDB	9 tables cinemafocus-* (Products 180 items; PITR off)	cinemafocus-store-staging
S3	cinemafocus-images (private, OAC, SSE-S3)	cinemafocusstore-staging-assets…
CloudFront	E2ET6E6X3C69LN	E1HLS76GNLZAPX
Cognito	ap-south-1_jWGc9kCbe (client cinemafocus-web-client)	ap-south-1_JZ4TuJBrW
Secrets Manager	none	OriginVerify secret
Shared	Account, billing, Lambda concurrency quota (10)	same

Isolation result

Tables, buckets, pools, APIs, roles, CloudFront and secrets are separate. The main site role contains no store resource ARNs. Shared by account: root keys (F-02), Lambda concurrency quota (F-06) and billing.

Remediation plan (needs your approval; nothing executed)

Step	Action	Findings
1 (urgent)	Confirm with read-only describe, then disable open self-signup (AllowAdminCreateUserOnly=true), make custom:role immutable or restrict client WriteAttributes, enable PreventUserExistenceErrors. Check no unexpected users hold admin.	F-01, F-12
2	Set API_GATEWAY_URL to https://57z1vidohf.execute-api.ap-south-1.amazonaws.com in .env.local and confirm Vercel prod value.	F-03
3	Discard the CDN/bucket edits in infra/serverless.yml. Never deploy them to this stack.	F-04
4	Validate upload folder, content type, extension and size; validate message fields; restrict stats to the current date; whitelist fields on updates.	F-05, F-07, F-10
5	Gateway throttling (for example 20 rps / burst 40); CORS to https://cinemafocus.in plus preview pattern; reserve concurrency so public traffic cannot starve the store.	F-06, F-08
6	Split IAM into public-read, admin-write and auth roles.	F-09
7	Enable PITR and deletion protection; attach SNS topic to alarms; set log retention; raise CloudFront minimum TLS and add a headers policy.	F-11, F-13, F-14, F-16
8	Replace root keys with an IAM Identity Center or role-based profile; delete the root access keys.	F-02
9	Add firebase-service-account.json to .gitignore and unstage it; rotate the key if it was ever shared.	F-15
10	Add tests: auth and admin route protection, upload validation, CORS, throttling, cross-app isolation.	F-17

Cost implications

Negligible: PITR on small tables, SNS alerts and throttling cost cents per month. Per-function roles and a WAF (optional, about USD 5 per month plus rules) are the only items with a noticeable bill.

Deployment and rollback

Take on-demand DynamoDB backups first. Apply changes as a single Serverless/CloudFormation update from a clean commit of infra/ using Serverless v3, with a staged test in the store-independent stage if desired. Rollback: redeploy the previous commit; Cognito changes are reversible with update-user-pool; keep the old template and the backups until verified.